

IAM Concepts: Authentication vs Authorization

The AAA Model

Authentication – "Are you who you say you are?"

Authorization – "Are you ALLOWED to do this?"

Accounting/Auditing – "What did you do?" (logs, attribution)

Identity Lifecycle

The full path of an identity:

Provision – create account, assign permissions on hire/onboarding

Manage – role changes, permission adjustments

Deactivate – disable when leaving, transfer ownership (critical!)

Offboard – delete/archive, revoke tokens

The #1 real-world IAM failure: forgotten deactivated accounts (old contractor accounts, shared "svc" accounts) become the attacker's doorway. **Identity sprawl** = unmanaged accounts = risk.

Least Privilege & "Why"

A user or service should have the minimum permissions to do its job – and nothing more:

No one needs root/SYSTEM for email

Service accounts should be limited, non-interactive, with no shell

Separation of duties – the person who approves a payment shouldn't be the one who submits it

Identity Stores

Store	Used For
Active Directory	Enterprise Windows + app SSO
Entra ID (Azure AD)	Microsoft cloud
LDAP	Generic directory (OpenLDAP)
Okta/Ping/Keycloak	Cloud IAM + SSO
Local accounts	Devices, Linux users

The sprawl of identity stores is itself a management problem – and a detection blind spot (if one store is unmanaged, accounts linger).

The "Why IAM" Pitch

80%+ of breaches involve credential misuse

IAM is where prevention AND detection both live

Every security control is meaningless if the wrong person holds the key

Mental model: IAM is the lock system of the building. Authentication = "does this key fit this door?" Authorization = "is this door even on your list?" Accounting = "the camera recorded you trying.:"

[← Module start](#)

[MFA, SSO & Federation →](#)